

PRUEBA TÉCNICA · CIBERSEGURIDAD

Detección y Respuesta a Incidentes

NIST SP 800-61 · MITRE ATT&CK v14 · Ley 1581

PREPARADO POR	Lady Marcela Romero Rivero
ROL	Líder de Ciberseguridad
CLIENTE	Simon Movilidad
ESCENARIO	FleetSec S.A.S. — Telemetría de flotas
FECHA	25 de agosto de 2026
VERSIÓN	1.0

CONFIDENCIAL — Exclusivo para Simon Movilidad

Tabla de contenido

0. Timeline reconstructed (from the embedded indicators)

1. Containment — exact AWS CLI (run top-to-bottom)

- Step 1 — Revoke credentials of the compromised IAM user
- Step 2 — Revoke already-issued STS sessions (stolen tokens)
- Step 3 — Revoke sessions & isolate the compromised EC2 (evidence first)
- Step 4 — Preserve CloudTrail / S3 / Flow-Log evidence (Write-Once)
- Step 5 — Block the attacker IP at WAF + quarantine the malicious ECS task

2. MITRE ATT&CK v14 mapping (≥ 6 techniques)

3. Root Cause Analysis (5 Whys + Swiss Cheese)

4. Executive summary for the CEO (≤ 1 page, no jargon)

5. Post-incident remediation plan (P1/P2/P3)

6. Ley 1581 — SIC notification (Colombia)

Framework: NIST SP 800-61r2 · **Severity:** SEV-1 (active data exfiltration, admin compromise)
Detection: GuardDuty + CloudTrail · **Status at T+02:00:** breach active ~2h · **PII involved:** YES (Ley 1581)

Sequence is non-negotiable: **preserve evidence** → **contain** → **eradicate** → **recover** → **lessons learned**.

0. Timeline reconstructed (from the embedded indicators)

UTC	Action	Technique
T+00:00	Console login from <code>185.220.101.22</code> (Tor) as IAMUser	T1078.004
T+00:15	<code>CreateLoginProfile</code> on <code>svc-monitoring</code>	T1098
T+00:22	<code>AttachUserPolicy</code> AdministratorAccess → <code>svc-monitoring</code>	T1098.001 / T1548
T+00:35	387× <code>s3:GetObject</code> / 8 min on <code>fleetpay-prod-drivers</code> (45.7 GB)	T1530
T+00:58	12× <code>kms:Decrypt</code> on <code>prod-data-key</code>	T1530
T+01:10	10.0.2.45 → 185.220.101.22:443, 49 GB outbound	T1567.002
T+01:40	<code>RegisterTaskDefinition</code> with <code>docker.io/attacker/exfil:latest</code>	T1610
T+01:45	<code>DeleteTrail</code> — BLOCKED by SCP	T1562.008
T+01:50	GuardDuty <code>Trojan:EC2/DNSDataExfiltration</code> on i-0abc1234def56789	T1071.004

1. Containment — exact AWS CLI (run top-to-bottom)

Preserve evidence BEFORE any destructive/network change. Never `stop` an instance before memory acquisition. Every command is reversible where noted.

Step 1 — Revoke credentials of the compromised IAM user

```
USER=svc-monitoring
# Inventory keys first (evidence)
aws iam list-access-keys --user-name "$USER" > ir-evidence/${USER}-keys.json
# Deactivate (preferred over delete – preserves for forensics)
for k in $(jq -r '.AccessKeyMetadata[].AccessKeyId' ir-evidence/${USER}-keys.json); do
  aws iam update-access-key --user-name "$USER" --access-key-id "$k" --status Inactive
done
# Kill console access (the attacker created a login profile at T+00:15)
aws iam delete-login-profile --user-name "$USER" || true
```

Rollback: re-activate keys / recreate login profile.

Step 2 — Revoke already-issued STS sessions (stolen tokens)

```
cat > /tmp/revoke.json <<'EOF'
{ "Version": "2012-10-17",
  "Statement": [{ "Effect": "Deny", "Action": "*", "Resource": "*",
```

```
"Condition": { "DateLessThan": { "aws:TokenIssueTime": "2026-08-23T02:00:00Z" } } } }
EOF
aws iam put-user-policy --user-name svc-monitoring \
  --policy-name RevokeSessionsTokenIssueBefore --policy-document file:///tmp/revoke.json
# Also detach the illegitimately attached admin policy
aws iam detach-user-policy --user-name svc-monitoring \
  --policy-arn arn:aws:iam::aws:policy/AdministratorAccess
```

`aws:TokenIssueTime` is the canonical way to invalidate live STS tokens immediately. **Rollback:**
`aws iam delete-user-policy --user-name svc-monitoring --policy-name RevokeSessionsTokenIssueBefore`

Step 3 — Revoke sessions & isolate the compromised EC2 (evidence first)

```
INSTANCE_ID=i-0abc1234def56789
mkdir -p ir-evidence
# 3a. Snapshot every attached volume BEFORE touching the network
for vol in $(aws ec2 describe-instances --instance-ids $INSTANCE_ID \
  --query 'Reservations[].Instances[].BlockDeviceMappings[].Ebs.VolumeId' --output text); do
  aws ec2 create-snapshot --volume-id $vol \
    --description "Forensic $INSTANCE_ID $(date -u +%Y%m%dT%H%M%S)" \
    --tag-specifications 'ResourceType=snapshot,Tags=[{Key=ir-evidence,Value=true},
{Key=incident,Value=INC-2026-001}]'
done
# 3b. Memory acquisition BEFORE stop (RAM is lost on stop)
aws ssm send-command --document-name "AWS-RunShellScript" --instance-ids $INSTANCE_ID \
  --parameters 'commands=["insmod /opt/lime.ko path=/tmp/mem.lime format=lime || dd if=/dev/
mem of=/tmp/mem.raw"]'
# 3c. Isolate to a pre-created quarantine SG (no ingress, egress only to collector)
aws ec2 modify-instance-attribute --instance-id $INSTANCE_ID --groups sg-quarantine
```

Rollback: `aws ec2 modify-instance-attribute --instance-id $INSTANCE_ID --groups sg-app-original`

Step 4 — Preserve CloudTrail / S3 / Flow-Log evidence (Write-Once)

```
aws s3 cp s3://fleetsec-cloudtrail-logs/AWSLogs/<acct>/CloudTrail/us-east-1/2026/08/23/ \
  s3://fleetsec-logs-<acct>/INC-2026-001/cloudtrail/ --recursive # Object Lock COMPLIANCE
bucket
aws cloudtrail lookup-events \
  --lookup-attributes AttributeKey=Username,AttributeValue=svc-monitoring \
  --start-time 2026-08-23T00:00:00Z --end-time 2026-08-23T02:00:00Z > ir-evidence/svc-
monitoring-events.json
aws logs start-query --log-group-name /fleetsec/vpc/flowlogs \
  --start-time $(date -d '2026-08-23T01:00:00Z' +%s) --end-time $(date -d
'2026-08-23T02:00:00Z' +%s) \
  --query-string 'fields @timestamp, srcAddr, dstAddr, bytes | filter srcAddr like /
10.0.2.45/ | sort bytes desc'
```

Step 5 — Block the attacker IP at WAF + quarantine the malicious ECS task

```
# Add to WAF IP set (immediate edge block)
aws wafv2 update-ip-set --name blocklist-ir --scope REGIONAL --id $IPSET_ID \
  --addresses 185.220.101.22/32 --lock-token $(aws wafv2 get-ip-set --name blocklist-ir --
scope REGIONAL --id $IPSET_ID --query LockToken --output text)
# Stop & deregister the attacker task definition
aws ecs list-tasks --cluster fleetsec --query 'taskArns' --output text | tr '\t' '\n' | \
```

```
while read t; do aws ecs stop-task --cluster fleetsec --task "$t" --reason "INC-2026-001
attacker image"; done
aws ecs deregister-task-definition --task-definition $(aws ecs list-task-definitions \
--query "taskDefinitionArns[?contains(@,'exfil')][0]" --output text)
```

2. MITRE ATT&CK v14 mapping (≥6 techniques)

Technique ID	Name	Tactic	Manifestation here	Mitigation (D3FEND)
T1078.004	Valid Accounts: Cloud	Initial Access / Persistence	Console login from Tor with valid IAM creds	Enforce MFA (D3-MFA); conditional access; deny Tor at WAF
T1098 / T1098.001	Account Manipulation: Additional Cloud Creds	Persistence	CreateLoginProfile + admin attach on svc-monitoring	SCP denying IAM mods to service users (D3-AM)
T1548	Abuse Elevation Control	Privilege Escalation	AttachUserPolicy AdministratorAccess	Least-privilege baseline; IAM Access Analyzer
T1530	Data from Cloud Storage	Collection	387× GetObject + 12× kms:Decrypt on driver data	S3 bucket policy w/ VPC-endpoint condition; CMK grants
T1567.002	Exfiltration to Cloud/Web	Exfiltration	45.7 GB → 185.220.101.22:443	VPC egress firewall / NetFw allowlist (D3-OEC)
T1610	Deploy Container	Execution	RegisterTaskDefinition w/ attacker image	ECR-only image policy; admission control on image origin
T1562.008	Impair Defenses: Disable Cloud Logs	Defense Evasion	DeleteTrail (blocked by SCP)	SCP DeleteTrail deny (worked); alert on attempt
T1071.004	App Layer Protocol: DNS	C2 / Exfil	GuardDuty DNS exfil on i-0abc...	Route53 Resolver DNS Firewall

3. Root Cause Analysis (5 Whys + Swiss Cheese)

5 Whys 1. Why was 45.7 GB of PII exfiltrated? svc-monitoring had AdministratorAccess. 2. Why did it get admin? AttachUserPolicy succeeded for a service user. 3. Why did that succeed? No SCP prevented IAM modification of service users by non-IAM-admin principals. 4. Why no such SCP? The Org SCP baseline was never reviewed after the single-account → org migration. 5. Why never reviewed? No periodic compliance-review process existed.

Real root cause: a missing *process* (periodic control review), not just a missing policy.

Swiss-cheese — layers that should have stopped this: - MFA on IAM console users: not enforced (login from Tor succeeded) - IP/geo allowlist on console: not enforced (Tor exit reached the console) - SCP on IAM mods to service users: absent - GuardDuty UnauthorizedAccess: fired — but reaction was too slow (2h) - SCP on DeleteTrail: blocked anti-forensics - VPC egress firewall: absent (49 GB left unimpeded) - CMK grants scoped to workloads: svc-monitoring could Decrypt prod-data-key

4. Executive summary for the CEO (≤1 page, no jargon)

Incident INC-2026-001 — Data breach brief For: CEO & executive team · **From:** Security Engineering · **Status:** Contained · **Date:** 2026-08-23

What happened. An attacker logged in through an anonymity network using the credentials of an internal service account, granted that account full administrator rights, and copied a large volume of driver data out of our systems over roughly two hours before we cut off access.

What was affected. - Data: driver personal data (names, national IDs, vehicle plates, GPS positions). - Approximate scale: ~45.7 GB from the `fleetpay-prod-drivers` store. - Duration: ~2 hours from first access to containment. - Systems: one processing server and one data bucket; core service stayed online.

Regulatory impact. - **Ley 1581:** notification to the SIC is required within **15 business days** of detection. Target submission: **2026-09-12**. Affected data subjects likely require direct notice (high risk to their rights). - Keep the incident record for at least 5 years.

Three immediate actions. 1. Enforce MFA + block anonymity networks on all admin access — SecOps, 48h. 2. Add guardrails so a service account can never be granted admin — SecOps, 72h. 3. Turn on outbound traffic controls so bulk data cannot leave — Networks, 7 days.

Estimated impact. Direct (forensics, legal, notification) + regulatory exposure up to **2,000 SMMLV** under Ley 1581 + reputational. Range to be refined after forensic scoping.

5. Post-incident remediation plan (P1/P2/P3)

Priority	Item	Effort	Owner	Due
P1	SCP: deny IAM mods to <code>svc-*</code> users by non-IAM-admin principals	1 d	SecOps	+3 d
P1	Enforce MFA + conditional access (block Tor/geo) on all IAM console users	2 d	SecOps+IT	+7 d
P1	VPC egress firewall with domain allowlist (Network Firewall)	1 w	Networks	+14 d
P1	Scope KMS key grants to workload roles; remove broad Decrypt	2 d	Platform	+7 d
P2	Migrate <code>svc-monitoring</code> to OIDC federation (no static keys)	2 w	Platform	+30 d
P2	ECR-only image policy + admission control (block docker.io/*)	1 w	Platform	+30 d
P2	Deploy the 4 Sigma rules to the SIEM + on-call paging	1 w	SecOps	+21 d
P2	Tabletop exercise on this exact scenario	0.5 d	SecOps	

Priority	Item	Effort	Owner	Due
				+30 d
P3	Documented, scheduled quarterly SCP/control review process	1 d	GRC	+60 d
P3	Route53 DNS Firewall for DNS-exfil TTP	3 d	Networks	+45 d

6. Ley 1581 — SIC notification (Colombia)

- **Timing:** within 15 business days of detection (detection 2026-08-23 → by 2026-09-12).
- **Channel:** SIC web portal, formal incident notification form.
- **Content:** nature of incident, PII categories affected (identificación, ubicación, placa), approx. number of data subjects, contact, measures taken/planned, possible consequences.
- **Data subjects:** direct notice (email + public notice) given high risk.
- **Record retention:** ≥ 5 years.